Segurança em Redes de Computadores

Heron Aragão Monteiro

Segurança em Redes de Computadores

Livro texto

Redes de Computadores e a Internet
(Uma abordagem top-down)

James F. Kurose e Keith W. Ross
6ª edição
Pearson Education do Brasil
2013

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- Introdução
  - O protocolo IP de segurança (IPsec) provê segurança na camada de rede
  - Protege os datagramas IP entre quaisquer entidades da camada de rede, incluindo hospedeiros e roteadores.
  - É usado para criar redes virtuais privadas (VPNs)
    - Que trabalham em cima da Internet pública

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

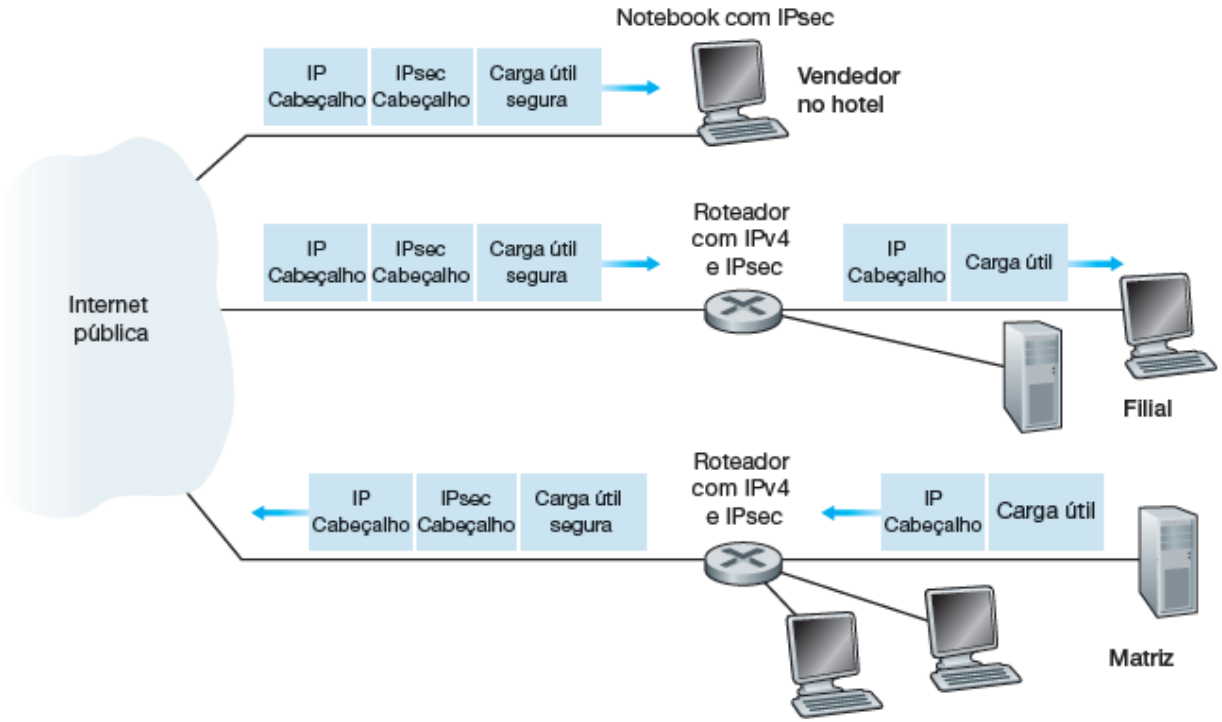
- IPSec e redes virtuais privadas (VPNs)
  - Rede privada
    - É necessária quando uma instituição que se estende por diversas regiões geográficas deseja ter sua própria rede IP
      - Para que seus hospedeiros e servidores consigam enviar dados um ao outro de uma maneira segura e sigilosa
    - Deve ser empregada uma rede física independente, completamente separada da Internet pública
    - Porém, uma rede privada pode ser muito cara, já que a instituição precisa comprar, instalar e manter sua própria infraestrutura de rede física

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- IPSec e redes virtuais privadas (VPNs)
  - Em vez de implementar e manter uma rede privada muitas instituições criam VPNs em cima da Internet pública
    - Todo o tráfego é enviado por meio da Internet pública e não de uma rede fisicamente independente
  - Para prover sigilo esse tráfego é criptografado antes de entrar na Internet pública

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- IPSec e redes virtuais privadas (VPNs)



Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- Os protocolos AH e ESP
  - O IPsec é um tanto complexo
  - Definido em mais de uma dúzia de RFCs (Request for Comments)
    - Publicações que documentam padrões, serviços e protocolos oficiais da Internet
  - Dois RFCs importantes
    - RFC 4301
      - Descreve a arquitetura de segurança IP geral
    - RFC 6071
      - Fornece uma visão geral dos protocolos IPsec

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- Os protocolos AH e ESP
  - Protocolo AH
    - Cabeçalho de Autenticação
      - Provê autenticação da origem e integridade dos dados
  - Protocolo ESP
    - Carga de Segurança de Encapsulamento
      - Provê autenticação da origem, integridade dos dados e sigilo
    - Sendo muito mais utilizado que o AH
      - Será o foco daqui em diante

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

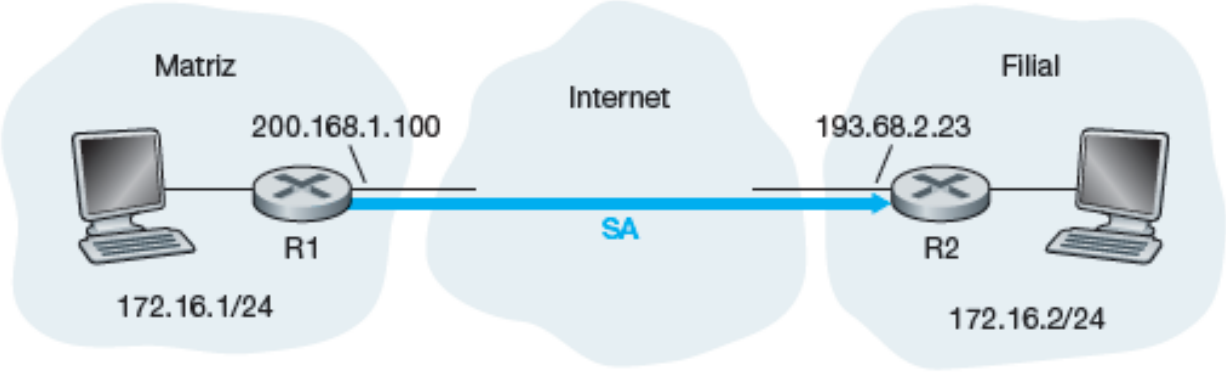
- Associação de segurança (SA)
  - Conexão lógica da camada de rede
  - Estabelecida entre pares de entidades da rede, tal como entre hospedeiros, entre dois roteadores, ou entre um hospedeiro e um roteador
    - Antes de enviar datagramas IPsec
  - É uma conexão lógica simples
    - Unidirecional do remetente ao destinatário
    - Se duas entidades querem enviar datagramas seguros entre si, então duas SAs precisam ser estabelecidas
      - Uma em cada direção

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- Associação de segurança (SA)
  - Nem todo o tráfego enviado à Internet pelos roteadores de borda ou pelos computadores será protegido por IPsec
    - O roteador de borda (e os computadores) emitirão na Internet tanto datagramas IPv4 comuns como datagramas IPsec seguros

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- Associação de segurança (SA)
  - Exemplificando
    - Usando o contexto de uma SA do roteador R1 ao roteador R2
      - Sendo R1 o roteador de borda da matriz e R2 o roteador de borda da filial



Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- Associação de segurança (SA)
  - Exemplificando
    - O Roteador R1 manterá as informações de estado sobre essa SA, incluindo
      - Um identificador de 32 bits para a SA, denominado Índice de Parâmetro de Segurança (SPI)
      - A interface remetente da SA (neste caso 200.168.1.100) e a interface destinatária da SA (neste caso 193.68.2.23)
      - O tipo de criptografia a ser usada (por exemplo, 3DES com CBC)
      - A chave de criptografia
      - O tipo de verificação de integridade (por exemplo, HMAC com MD5)
      - A chave de autenticação

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

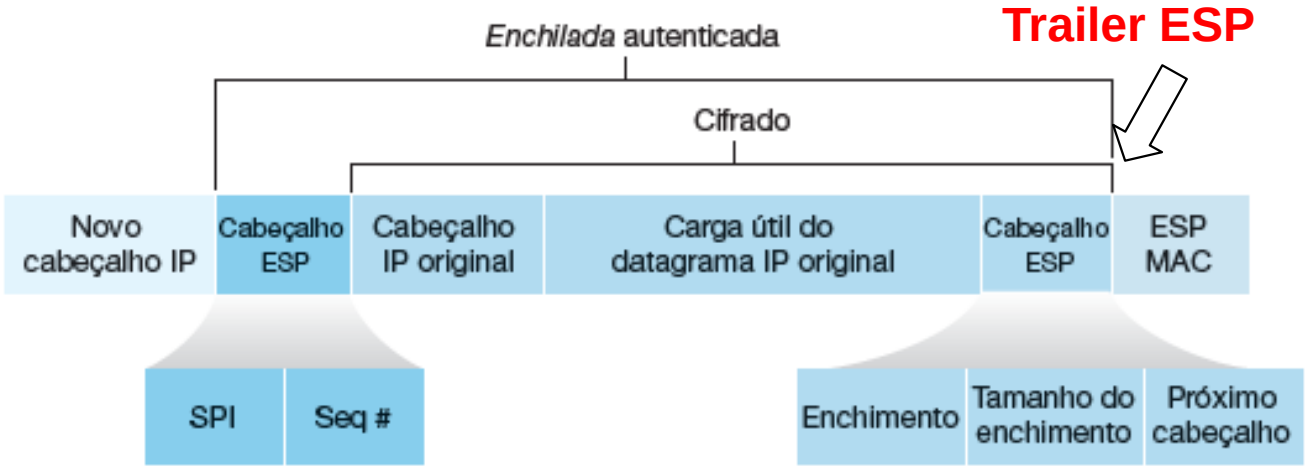
- Associação de segurança (SA)
  - Exemplificando
    - Quando o roteador R1 precisa construir um datagrama IPsec para encaminhar por essa SA
      - Ele acessa as informações de estado para determinar como deveria autenticar e criptografar o datagrama
    - O roteador R2 manterá as mesmas informações de estado sobre essa SA e as usará para autenticar e decodificar qualquer datagrama IPsec que chegar da SA
    - Uma entidade IPsec (roteador ou hospedeiro) muitas vezes guarda essas informações de estado para muitas SAs
      - No exemplo sobre a VPN com n vendedores, cada roteador de borda guarda informações de estado para (2 + 2n) SAs
      - Uma entidade IPsec armazena as informações de estado para todas as suas SAs em seu Banco de Dados de Associação de Segurança (SAD)
        - Que é uma estrutura de dados do núcleo do sistema operacional

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- O datagrama IPsec
  - O datagrama IPsec possui duas formas diferentes de pacotes
    - Para o modo túnel
      - Mais apropriado para as VPNs
    - Para o modo transporte
  - O modo túnel, por ser mais implementado do que o modo transporte, será o foco daqui para frente

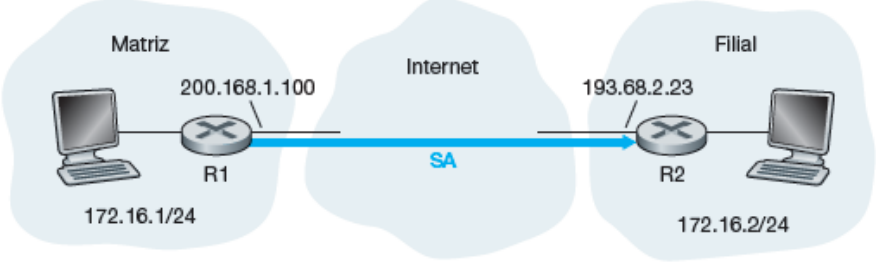
Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- O datagrama IPsec
  - Formato do datagrama

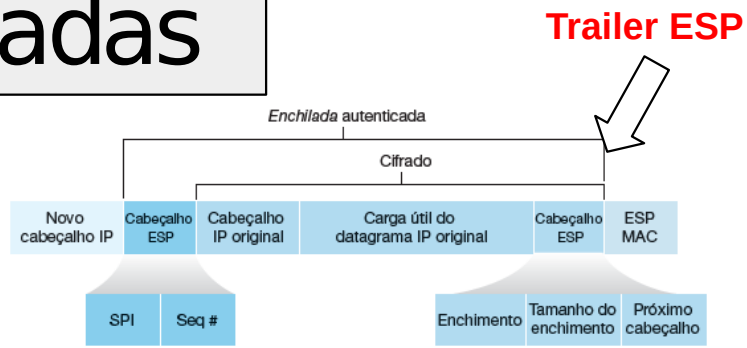


Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- O datagrama IPsec
  - Formato do datagrama
    - Examinando os campos do IPsec no contexto do exemplo anterior
      - Suponha que o roteador R1 receba um datagrama IPv4 comum do hospedeiro 172.16.1.17 (na rede da matriz) destinado ao hospedeiro 172.16.2.48 (na rede da filial)



Segurança na camada de rede IPSEC e Redes Virtuais Privadas



- O datagrama IPsec
  - Formato do datagrama
    - Examinando os campos do IPsec no contexto do exemplo anterior
      - R1 utiliza a seguinte receita para converter o “datagrama IPv4 original” em um datagrama IPsec
        - Anexa ao final do datagrama IPv4 original (que inclui os campos de cabeçalho originais) um campo de “trailer ESP”
        - Codifica o resultado utilizando o algoritmo e a chave especificados pela SA
        - Anexa na frente dessa quantidade codificada um campo chamado “cabeçalho ESP”; o pacote resultante é chamado de “enchilada”
        - Cria uma autenticação MAC sobre a enchilada inteira, usando o algoritmo e a chave especificados na SA
        - Anexa a MAC atrás da enchilada, formando a carga útil
        - Por fim, cria um cabeçalho IP novo com todos os campos de cabeçalho IPv4 clássicos (juntos, normalmente com 20 bytes de comprimento), o qual se anexa antes da carga útil

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- O datagrama IPsec
  - Formato do datagrama
    - Examinando os campos do IPsec no contexto do exemplo anterior
      - O datagrama IP resultante é um autêntico datagrama IPv4
        - Com os tradicionais campos de cabeçalho IPv4 acompanhados por uma carga útil, que contém um cabeçalho ESP, o datagrama IP original, um trailer ESP e um campo de autenticação ESP
          - Com o datagrama original e o trailer ESP cifrados
      - O datagrama IP original possui o endereço IP remetente 172.16.1.17 e o endereço IP destinatário 172.16.2.48
      - Em razão de o datagrama IPsec incluir o IP original, esses endereços são inclusos (e cifrados) como parte da carga útil do pacote IPsec

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- O datagrama IPsec
  - Formato do datagrama
    - Examinando os campos do IPsec no contexto do exemplo anterior
      - Os endereços IP remetente e destinatário que estão no novo cabeçalho IP, localizado à esquerda do datagrama IPsec são estabelecidos para as interfaces do roteador remetente e destinatário nas duas extremidades dos túneis, isto é, 200.168.1.100 e 193.68.2.23
      - Além disso, o número do protocolo nesse novo campo de cabeçalho IPv4 não será o número do TCP, UDP ou SMTP
        - Mas igual a 50, determinando que esse é um datagrama IPsec que está utilizando o protocolo ESP

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- O datagrama IPsec
  - Formato do datagrama
    - Examinando os campos do IPsec no contexto do exemplo anterior
      - Após R1 enviar um datagrama IPsec à Internet pública, ele passará por diversos roteadores antes de chegar ao R2
    - Campos que compõem a enchilada
      - Trailer ESP, composto dos campos
        - Enchimento
          - Preenchimento necessário para se adequar à cifra de blocos, que exige que a mensagem a ser cifrada seja um múltiplo inteiro do comprimento do bloco
        - Tamanho do enchimento

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- O datagrama IPsec
  - Formato do datagrama
    - Campos que compõem a enchilada
      - Trailer ESP, composto dos campos
        - Próximo cabeçalho
          - Identifica o tipo de dados (por exemplo, UDP) contidos no campo de dados da carga útil
      - Os dados da carga útil (em geral o datagrama IP original) e o trailer ESP são concatenados e, então, cifrados

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- O datagrama IPsec
  - Formato do datagrama
    - Campos que compõem a enchilada
      - Cabeçalho ESP
        - Enviado em aberto
        - Composto dos campos
          - SPI
            - Indica para a entidade destinatária a Associação de Segurança (SA) à qual o datagrama pertence
          - Número de sequência
            - Usado para a proteção contra ataques de repetição

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- O datagrama IPsec
  - Formato do datagrama
    - A enchilada é autenticada, sendo gerado um ESP MAC

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- Datagrama chegando no destino (R2)
  - Verifica se o endereço do destino é o próprio R2
  - Verifica se o campo de protocolo igual a 50
  - Usa o SPI para determinar qual a SA o datagrama pertence
  - Calcula o MAC da enchilada e compara com MAC ESP
  - Verifica o campo numérico de sequência para ver se o datagrama é novo

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- Datagrama chegando no destino (R2)
  - Decodifica a unidade cifrada usando o algoritmo e a chave de criptografia associados à SA
  - Remove o enchimento extra
  - Extrai o datagrama IP original básico
  - Encaminha o datagrama original à rede da filial em direção ao destino final

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- Resumo dos serviços IPsec
  - De acordo com o que foi apresentado IPsec oferece
    - Sigilo
    - Autenticação da origem
    - Integridade dos dados
    - Proteção contra ataque de repetição

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- IKE: Gerenciamento de chave no IPsec
  - Como dito anteriormente, uma entidade IPsec armazena as informações de estado das suas SAs em seu Banco de Dados de Associação de Segurança (SAD)
  - Quando uma VPN possui um pequeno número de pontos finais o administrador de rede pode inserir, manualmente, as informações sobre a SA nos SADs do ponto de chegada
    - Impraticável para uma VPN grande

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- IKE: Gerenciamento de chave no IPsec
  - IKE é um protocolo de troca de chaves
  - Ele automatiza o processo de criação das SAs
  - Tem semelhanças com o processo de apresentação (handshake) do TLS
  - O IKE tem dois certificados de troca de entidades, autenticação de negociação e algoritmos de criptografia
    - Troca informações de chave para criar chaves de sessão nas SAs IPsec

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- IKE: Gerenciamento de chave no IPsec
  - O processo é feito em duas fases
    - Que será ilustrado tomando como exemplo a comunicação dos roteadores R1 e R2 anteriores
    - Primeira fase
      - É criada uma IKE SA bidirecional entre os roteadores, diferente da SA IPsec
        - Provê um canal cifrado e autenticado entre os dois roteadores
        - São estabelecidas as chaves para a criptografia e autenticação para o IKE SA
        - É também estabelecido um segredo mestre para calcular chaves SA IPsec, na segunda fase
        - R1 e R2 não revelam a sua identidade, não usando as suas chaves privadas

Segurança na camada de rede IPSEC e Redes Virtuais Privadas

- IKE: Gerenciamento de chave no IPsec
  - O processo é feito em duas fases
    - Segunda fase
      - Os dois roteadores revelam a sua identidade assinando as suas mensagens
      - As suas identidades não são reveladas a um analisador passivo
        - Porque são enviadas por um canal seguro IKE SA
      - Os dois lados negociam os algoritmos de autenticação e criptografia
      - É criada uma SA em cada direção
    - No final as chaves de sessão de criptografia e autenticação são estabelecidas